



Detec Logo

Detec (Agentic-Governance) Security Technical Report

Report type: Internal technical report (security/engineering)
Scope: Performance benchmarks, lab validation results, automated test inventory, CI security posture
Source: Playbook v0.4, lab-runs, collector/api/protocol test suites, CI workflows, calibration pipeline
Generated: 2026-03-14
Classification: Internal use; full-fidelity diagnostics. For external/buyer-facing summary, see INIT-32 sanitization profile.

1. Executive Summary

This report consolidates all technical validation evidence for the Detec endpoint detection and governance stack: automated test counts, lab run outcomes, confidence calibration, performance benchmarks, and CI/security job coverage. It is intended for detection engineering, security architecture, and operations.

Metric	Value
Total automated tests	980 (626 collector + 306 API + 48 protocol)
Collector test modules	34
API test modules	27
Completed lab runs (with RESULTS)	11 (10 tool/scenario runs + 1 evasion run)
Calibration fixtures (replay harness)	10 (8 lab-run fixtures + 2 behavioral)

Metric	Value
CI jobs (main + security)	12 (7 in ci.yml, 5 in security.yml)
Security findings (tracked)	14 (3 fixed, 11 open/accepted)

Release gate status: All CI jobs must pass on push/PR to main. Calibration regression runs on every change. Security tests (pentest, gateway, rate limits, agent security) and SAST/SCA/secrets scans are required per branch protection recommendations.

Known gaps: LAB-RUN-015 (Cowork gap scenarios) protocol-only; 5 tools (Aider, LM Studio, Continue, GPT-Pilot, Cline) have synthetic scanner tests only, no live lab runs. Benchmark report generator (INIT-32) is specified but not yet implemented; this document serves as the current consolidated technical report.

2. Automated Test Inventory

2.1 Test Counts by Component

Component	Tests collected	Entry point	Notes
Collector	626	pytest collector/tests/	Scanners, confidence, policy, telemetry, providers, calibration, security, latency
API	306	pytest api/tests/	Auth, events, endpoints, policies, billing, gateway, security, tenant isolation
Protocol	48	pytest protocol/tests/	Wire format, connection,

Component	Tests collected	Entry point	Notes
			msgpack framing
Total	980		

Counts obtained via `pytest ... --collect-only -q` (2026-03-14). AGENTS.md previously cited 233 + 244 + 48; the codebase has grown (e.g. provider matrix, scanner suites, security tests).

2.2 Collector Test Modules (34 files)

Module	Focus
test_agent_security.py	Agent tampering, config integrity, downgrade
test_attack_mapping.py	MITRE/attack mapping
test_behavioral_scanner.py	Behavioral signal detection
test_calibration.py	Lab replay harness, band regression, cross-tool ordering
test_cgroup_network_block.py	cgroup network blocking
test_confidence.py	Confidence scoring, weights, bands
test_ebpf_provider.py	eBPF provider (mock)
test_enforcement_e2e.py	End-to-end enforcement
test_enforcement_hardening.py	Enforcement hardening
test_enforcement_posture.py	Posture evaluation
test_esf_provider.py	macOS Endpoint Security (mock)
test_etw_provider.py	Windows ETW (mock)
test_event_store.py	EventStore ring buffer, retention
test_event_store_alerts.py	Alert callbacks, thresholds
test_evasion_scanner.py	Evasion indicators (e.g. trailer stripping)
test_emitter.py	HTTP/TCP emission

Module	Focus
test_latency_benchmarks.py	EventStore push/throughput/latency (see Section 5)
test_main_integration.py	Main entry, dry-run, config
test_mcp_scanner.py	MCP scanner
test_pipeline.py	Scan pipeline
test_policy.py	Policy engine
test_polling_provider.py	Polling telemetry provider
test_provider_integration.py	Provider integration
test_provider_registry.py	Provider registry, get_best_provider
test_scheduler_artifacts.py	Scheduler artifacts
test_scanner_aider.py	Aider scanner (synthetic)
test_scanner_cline.py	Cline scanner (synthetic)
test_scanner_continue.py	Continue scanner (synthetic)
test_scanner_gpt_pilot.py	GPT-Pilot scanner (synthetic)
test_scanner_lm_studio.py	LM Studio scanner (synthetic)
test_scanner_consistency.py	Scanner consistency
test_service_recovery.py	Service recovery
test_tcp_emitter.py	TCP/binary protocol emitter
test_validator.py	Event schema validation

2.3 API Test Modules (27 files)

Module	Focus
test_agent_download.py	Agent download endpoint
test_auth.py	Login, JWT, sessions
test_auth_tokens.py	Invite, reset, token handling

Module	Focus
test_billing.py	Stripe billing, tiers
test_crowdstrike.py	CrowdStrike EDR stub
test_crowdstrike_rtr.py	RTR integration
test_demo.py	Demo flows
test_edr_integration_validation.py	EDR enrichment validation
test_endpoints.py	Endpoint CRUD, heartbeat
test_enforcement_provider.py	Enforcement provider
test_enforcement_posture_rbac.py	Posture RBAC
test_enforcement_router.py	Enforcement routing
test_enrichment.py	Event enrichment
test_events.py	Event ingest, query
test_gateway.py	Binary gateway (TCP)
test_gateway_security.py	Gateway auth, hostname length, limits
test_integration_flows.py	Integration flows
test_policies.py	Policy CRUD, baseline
test_rate_limits.py	Rate limiting
test_reports.py	Reports
test_response_playbooks_schema.py	Playbook schema
test_schema_telemetry.py	Telemetry schema
test_security_pentest.py	Auth, BOLA, input validation, playbooks
test_sso.py	SSO
test_tenant_isolation.py	Tenant isolation
test_tenants.py	Tenant CRUD
test_webhooks.py	Webhooks

2.4 Protocol Tests (48 tests)

Wire protocol: msgpack framing, message types, connection lifecycle, binary gateway compatibility. No submodule breakdown; single package under protocol/tests/.

3. Lab Validation Results

3.1 Completed Runs (protocol + RESULTS)

All runs follow playbook Section 12 methodology: Phase 1–5, Signal Observation Matrix, confidence trace, INIT-43 correlation rules (C1–C4), residual ambiguity. Evidence directories are not committed (sensitive); paths and file counts are recorded in each RESULTS file.

Run ID	Date	Tool	Scenario	Result	Confidence	Notes
LAB-RUN-001	2026-02-26	Claude Code v2.1.59	CC-POS-01	Conditional Pass	0.71 (Medium)	9/12 IOCs; network under-instrumented; 10 playbook findings
LAB-RUN-002	2026-02-26	Claude Code v2.1.59	CC-POS-02	Pass	(validated)	Closed RUN-001 gaps: script capture, git IOC, child chain 500ms
LAB-RUN-EVASION-001	2026-02-26	Claude Code v2.1.59	CC-EVA-01	Pass (6/6)	N/A	Co-Authored-By evasion; trailer one-way signal; Rule C6 added
LAB-RUN-003	2026-02-26	Ollama v0.17.0	OL-POS-01	Conditional Pass	0.69 (Medium)	First Class B; 9/9 IOCs; Class B weight

Run ID	Date	Tool	Scenario	Result	Confidence	Notes
						calibration proposed
LAB-RUN-004	2026-03-02	Cursor v2.5.26	CUR-POS-01	Pass	0.79 (High)	First High without sudo/EDR; 9/9 IOCs
LAB-RUN-005	2026-03-02	GitHub Copilot v0.37.9	CP-POS-01	Conditional Pass	0.45 (Medium)	First Class A; unauth scenario; 4/11 IOCs (auth would raise)
LAB-RUN-006	2026-03-02	Open Interpreter v0.4.3	OI-POS-01	Conditional Pass	0.525 (Medium)	10/14 IOCs; generic process name; Class C not generalizable
LAB-RUN-007	2026-03-02	OpenClaw v2026.3.1	OC-POS-01	Conditional Pass	0.80 (High)	First Class D; 18/27 IOCs; LaunchAgent, credentials, self-modification
LAB-RUN-013	2026-03-05	OpenClaw v2026.3.1 (local LLM)	OC-POS-05	Conditional Pass	0.725 (Medium)	Same infra as 007; behavior down (0.8B model failed tool-use)
LAB-RUN-014	2026-03-05	Claude Cowork v1.1.4498	CW-POS-01	Pass	0.905 (High)	First VM-based tool; 10 GB rootfs; strongest identity signal

3.2 Protocol-Only (Pending)

Run ID	Tool / scenario	Protocol	Notes
LAB-RUN-001-root	Claude Code (root rerun)	LAB-RUN-001-ROOT-RERUN.md	Template; full visibility
LAB-RUN-008-012	Aider, LM Studio, Continue, GPT-Pilot, Cline	TEMPLATE-*.md	Synthetic scanner tests only; no live lab
LAB-RUN-015	Claude Cowork (CW-POS-02/03, skill-creator)	LAB-RUN-015-claude-cowork-scheduled-dxt-skill.md	Gap scenarios; run pending

3.3 Evasion (LAB-RUN-EVASION-001)

Six vectors tested against Co-Authored-By trailer: settings suppression, amend, rebase, commit-msg hook, filter-branch, global template hook. All succeeded. Finding: trailer is high-confidence when present, zero-confidence when absent. Evasion counter-indicators and Rule C6 (evasion intent boost) added to playbook. Most dangerous vector: commit-msg hook (no forensic trace).

4. Calibration and Regression

4.1 Fixture Corpus

Fixtures live in `collector/tests/fixtures/lab_runs/`. The replay harness (`test_calibration.py`) loads all `*.json` fixtures, runs them through `compute_confidence()` and `classify_confidence()`, and asserts expected band and (optionally) score range. Cross-tool regression: relative ordering of tools by score must be preserved.

Fixture	Tool	Expected band	Score range
LAB-RUN-001.json	Claude Code	Medium	0.68–0.74
LAB-RUN-003.json	Ollama	Medium	0.66–0.72
LAB-RUN-004.json	Cursor	High	0.76–0.82

Fixture	Tool	Expected band	Score range
LAB-RUN-005.json	GitHub Copilot	Medium	0.42–0.48
LAB-RUN-006.json	Open Interpreter	Medium	0.50–0.56
LAB-RUN-007.json	OpenClaw	High	0.77–0.83
LAB-RUN-013.json	OpenClaw (local LLM)	Medium	0.66–0.72
LAB-RUN-014.json	Claude Cowork	High	0.86–0.92
behavioral_false_positive.json	(false positive)	Low	(behavioral)
behavioral_agentic_bot.json	(agentic bot)	(behavioral)	(behavioral)

4.2 CI Automation

- **Calibration Regression** (ci.yml): `pytest collector/tests/test_calibration.py -v` on every push/PR to main. Dedicated job; failures block merge.
- **Collector Tests**: Full `pytest collector/tests/` includes calibration tests.
- No path filtering: any code change can affect confidence; harness is fast (<1s).

Reference: docs/architecture-calibration-pipeline.md.

5. Performance Benchmarks

Source: `collector/tests/test_latency_benchmarks.py`. Marked `@pytest.mark.benchmark` and `@pytest.mark.slow`; may be excluded in default runs via `pytest` config.

Benchmark	Target	Description
Push to alert callback	< 1 ms	Single <code>push_process ()</code> to EventStore with <code>on_alert</code> callback; end-to-end latency including callback invocation
Throughput (10k events)	10,000 events in < 1 s	Sequential <code>push_process ()</code> into EventStore (<code>max_events=20k</code> , retention 60s)
<code>get_process_events</code> (10k)	< 100 ms	Retrieve 10,000 process events from store after loading

These validate that the in-memory EventStore ring buffer does not become a bottleneck under typical scan burst volumes. No API or gateway throughput benchmarks are currently in tree; INIT-30 (metrics pipeline) and INIT-32 (benchmark report generator) would extend this.

6. CI and Security Posture

6.1 Main CI (ci.yml)

Job	What it runs
Build Dashboard	<code>npm ci + npm run build</code> in dashboard/
Collector Tests	<code>pytest collector/tests/</code> (includes calibration)
Calibration Regression	<code>pytest collector/tests/test_calibration.py -v</code>
API Tests	<code>pytest api/tests/</code> (Postgres 16, env from workflow)
Provider Tests	ESF/ETW/eBPF/provider registry tests on ubuntu, macos, windows
ESF Helper Build	<code>make -C collector/providers/esf_helper</code> ; upload artifact
Docker Build	Build API and dashboard images

6.2 Security Workflow (security.yml)

Job	What it runs
Security Tests	API: test_security_pentest, test_gateway_security, test_rate_limits. Collector: test_agent_security
Static Analysis (Semgrep)	p/owasp-top-ten, p/cwe-top-25, p/python, p/javascript
Dependency Audit (Trivy)	FS scan; CRITICAL,HIGH → exit 1
Dependency Audit (pip-audit, npm audit)	pip-audit (Python); npm audit --audit-level=moderate (dashboard)
Secrets Detection (Gitleaks)	Hardcoded secrets scan

Recommended branch protection: require Security Tests, Semgrep, at least one dependency audit, Gitleaks. See docs/ci-security.md.

6.3 Security Findings Summary

From docs/security-findings.md (mini assessment: auth, playbooks, gateway, tenant isolation, input validation):

Severity	Count	Fixed
Medium	1	0 (F-005: orchestrator runs default playbooks only; product decision)
Low	5	3 (F-006 payload limit, F-007 hostname length, F-014 schema depth)
Informational	6	0 (design/optional)
Positive	2	N/A

Findings are traceable to specific files and remediation status; no critical issues. Hardening checklist: docs/hardening-checklist.md.

7. Evidence Index and Traceability

Artifact type	Location	Integrity / notes
Lab protocols	lab-runs/LAB-RUN-.md, -TEMPLATE-*.md	Versioned in repo
Lab results	lab-runs/*-RESULTS.md	Versioned; evidence dirs not committed
Calibration fixtures	collector/tests/fixtures/lab_runs/*.json	Versioned; replayed in CI
Playbook lab log	playbook/PLAYBOOK-v0.4-*.md Section 12.5	Single source of run log
Test suites	collector/tests/, api/tests/, protocol/tests/	Run in CI; counts in this report
CI definitions	.github/workflows/ci.yml, security.yml	Source of job list
Security findings	docs/security-findings.md	ID-based tracking
Calibration design	docs/architecture-calibration-pipeline.md	Pipeline and fixture format
Lab index	docs/lab-runs-and-results.md	Index of protocols, results, scripts

8. Limitations and Gaps

- **Lab coverage:** Five tools (Aider, LM Studio, Continue, GPT-Pilot, Cline) have only synthetic scanner tests; confidence for these is not empirically calibrated. LAB-RUN-015 (Cowork gap scenarios) not yet executed.
- **Performance:** Only EventStore benchmarks are in tree; no API/gateway load or end-to-end latency benchmarks.
- **Benchmark report generator:** INIT-32 defines output types and data model; implementation (versioned, reproducible reports) is not yet done. This document is the current consolidated technical report.
- **Evasion:** Co-Authored-By evasion is documented; no automated evasion suite (INIT-31) yet; other tools' attribution signals not systematically evasion-tested.

9. Action Plan (Remediation and Follow-Up)

Priority	Item	Owner / ref
1	F-005: Resolve product intent (default-only vs custom playbooks on ingest)	Product / eng
2	LAB-RUN-015: Execute Cowork gap scenarios when ready	Detection eng
3	Implement INIT-32 benchmark report generator (internal + external outputs)	Eng
4	Add API/gateway performance benchmarks if release criteria require	Eng
5	Document F-004 (agent role for playbooks API) in API/playbook docs	Docs

End of report. For playbook methodology, detection profiles, and correlation rules, see [playbook/PLAYBOOK-v0.4-agentic-ai-endpoint-detection-governance.md](#). For lab run procedures and capture scripts, see [lab-runs/](#) and [docs/lab-runs-and-results.md](#).